



u n i d a d e s

6-7

Software Malicioso

Medidas de protección

Ideas clave

SOFTWARE MALICIOSO

Concepto de Software Malicioso

Clasificación

Denegación de servicio

Publicidad y Correo no deseado

Ingeniería Social.
Fraudes informáticos

Según su nivel de peligrosidad

Bajo
Medio
Elevado

Según su forma de propagación

Virus
Gusanos
Trojanos

Según las acciones que realiza

Software dañino
Software no dañino

Suplantación de identidad

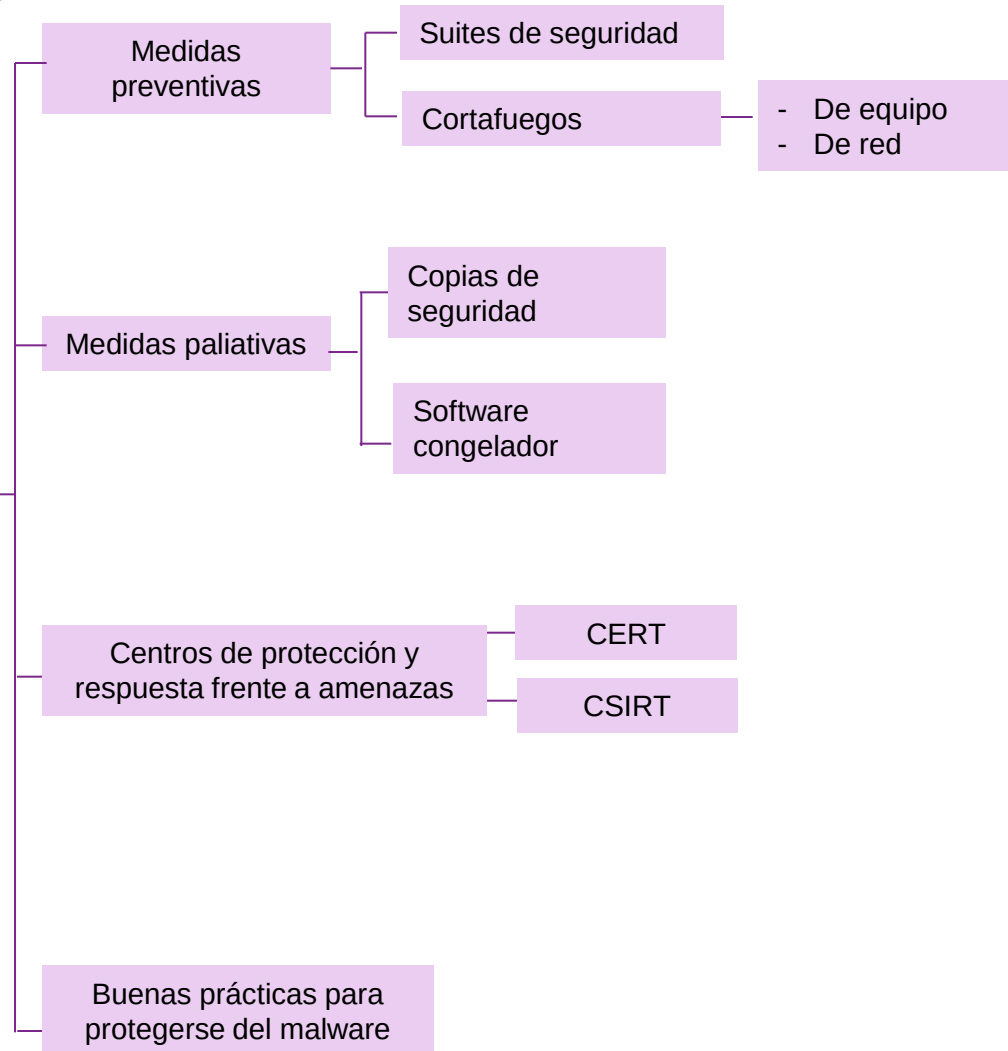
Phishing
Vishing
SMiShing
Grooming

Cadenas de correos

Correos millonarios

Ideas clave

MEDIDAS DE PROTECCIÓN CONTRA EL MALWARE



Software Malicioso

- ✓ Concepto de software Malicioso
- ✓ Clasificación del Malware
- ✓ Denegación del servicio
- ✓ Publicidad y Correo no deseado
- ✓ Ingeniería Social. Fraudes Informáticos

Medidas de protección

- ✓ Medidas de protección
- ✓ Centro de protección y respuesta frente a amenazas
- ✓ Buenas prácticas para protegerse del malware

1. Concepto de software malicioso

El **software malicioso** es cualquier software que puede representar una amenaza al sistema o resulta molesto al usuario.

Puede modificar el funcionamiento de un equipo informático, alterar la información que procesa, ya sea borrándola, modificándola o enviándola sin nuestro conocimiento e incluso tomar control del equipo infectado.

El malware se propaga a través de dos vulnerabilidades:

Vulnerabilidad del software

- Se explotan debilidades del sistema operativo o de algún programa.
- Algunos malwares son capaces de copiarse a sí mismos y enviarse automáticamente a través de la red e infectar gran número de equipos

Vulnerabilidad asociada a personas

- Los propios usuarios por desconocimiento o exceso de confianza contribuyen a su propagación.
- Recomendación: sentido común y prudencia

La mayoría del malware desarrollado afecta a sistemas Microsoft pero ya ninguna plataforma (MacOS, Linux,..) está exenta. Los sistemas móviles también están siendo afectados (Android, Symbian, iOS).

2. Clasificación del Malware

Existe gran cantidad de software malicioso y es difícil su clasificación. Elegimos para ello los siguientes criterios:

- ✓ Impacto producido en la víctima
- ✓ Forma de propagación
- ✓ Acciones que realiza

<https://blog.kaspersky.es/malware-para-dispositivos-moviles-2013/2562/>

<http://www.pandasecurity.com/spain/mediacenter/noticias/pandalabs-detecta-mas-de-21-millones-de-nuevas-amenazas/>



2. Clasificación del Malware

Impacto producido en las víctimas

Atendiendo a este criterio, distinguimos **tres niveles de peligrosidad**:

- Bajo
- Medio
- Elevado

Para determinar este grado se estudia:

- ✓ La gravedad de las acciones que produce
- ✓ Velocidad y facilidad de propagación
- ✓ Cantidad de infecciones producidas

Forma de propagación

Según la forma de propagación, los tipos de malware más importantes son:

- Virus
- Gusanos
- Troyanos

2. Clasificación del Malware

Forma de propagación

✓ Virus:

Software malicioso que tiene por finalidad alterar el funcionamiento de un equipo informático sin el conocimiento o consentimiento de su usuario corrompiendo o destruyendo archivos.

Características

- Se propaga al ejecutarse en local (RAM) infectando a otros ficheros o al visitar páginas web “poco fiables”
- Necesita la intervención humana para ejecutarlo una primera vez.
- Cada vez que se ejecute el archivo infectado, se ejecutará de nuevo el virus.
- Si reinstalamos el software afectado sin apagar el equipo, volverá a infectarse, el virus sigue en memoria
- Efectos: Molestos (aunque inofensivos) o graves (modificación del registro de Windows, borrado de archivos)

2. Clasificación del Malware

Forma de propagación

✓ Gusanos:

Tipo de malware que se propaga automáticamente sin necesidad de infectar a otros archivos. Puede duplicarse así mismo. No necesita intervención humana.

Características

- Están pensados para **consumir recursos** de un sistema o de una red de comunicaciones hasta saturarlo y provocar su caída.

Formas de difusión

- Programas de mensajería instantánea o canales de chat
- Recursos compartidos de una red local
- Redes P2P
- Correo electrónico

Desinfección

- Más sencilla que la de un virus: No modifican archivos. Sólo modifican parámetros del sistema (registro, lista de programas que se ejecutan al iniciar el ordenador).

2. Clasificación del Malware

Forma de propagación

✓ Troyanos:

Software malicioso que se introduce en el ordenador y se instala en él, aparentando ser un programa inofensivo. Su **finalidad** es permitir a un usuario no autorizado **tomar el control** de la máquina infectada.

Características

- La infección se produce al ejecutar un programa infectado.
- El programa funciona correctamente y en un segundo plano, de forma invisible, se instala el troyano.
- Tendremos: un cliente (**equipo atacante**) y un servidor (**equipo infectado**)
- El servidor recibe órdenes del cliente (intruso) y las ejecuta, enviando información solicitada → 2 tipos de conexión:
 - **Conexión directa** → El cliente (atacante) se conecta al servidor para enviarle órdenes. Más frecuente.
 - **Conexión indirecta** → El servidor (ordenador infectado) envía directamente la información al cliente. Más efectiva (muchos firewalls no analizan la información saliente).

2. Clasificación del Malware

Forma de propagación

Especies más habituales de troyanos:

- **Backdoor** → Permite el acceso remoto a un atacante sobre sistema operativo, aplicaciones, webs, recursos.
 - Podría robar, cualquier información personal transmitida o recibida en dicho ordenador y usar éste con cualquier propósito, por ejemplo crear una botnet.
- **Keylogger** → Captura las pulsaciones de tecla realizadas en el equipo de la víctima para enviarlas al atacante.
- **Downloader** → Su misión es descargar archivos maliciosos y ejecutarlos en el ordenador infectado
- **Proxy** → El intruso utiliza la red infectada como un servidor proxy, accediendo a la web a través del mismo y encubriendo su verdadera identidad.
- **Dialer** → Usa el ordenador infectado para hacer llamadas de alto coste

2. Clasificación del Malware

Forma de propagación

✓ Troyanos:

Recomendaciones

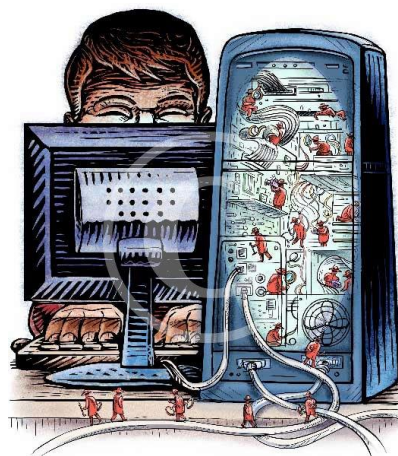
- Extremar precauciones al descargar archivos → web's oficiales o de confianza.
- Usar herramientas de software que garanticen integridad de lo que descargamos → firma digital
- Ojo con los adjuntos. Ante la duda NO ABRIR.
- Usar antivirus actualizado.
- Software del sistema operativo actualizado.
- Activar el Firewall.

2. Clasificación del Malware

Acciones que realiza

Según las acciones que realiza, podemos diferenciar:

- ✓ Software malicioso no dañino
- ✓ Software malicioso dañino



2. Clasificación del Malware

Acciones que realiza

- ✓ **Software malicioso no dañino (grayware):**
Realiza acciones molestas pero no dañinas, tales como mostrar publicidad no deseada, mostrar mensajes falsos, asustar al usuario con algún tipo de broma, etc.

Tipos:

- **Spyware**
- **Adware**
- **Hijacking**
- **Jokes o bromas**
- **Bulos o hoaxes**

2. Clasificación del Malware

Acciones que realiza

✓ **Grayware:** software malicioso no dañino

Spyware

- Trata de conseguir información del usuario como estadísticas de navegación, tiempo que está en una página.
- Si trata de obtener beneficio de esa información ya no sería Grayware, sería Malware.

Adware

- Muestra información intrusiva (ventanas emergentes)
- Puede camuflar la acción de un malware
- Algunos programas legítimos de pago incluyen Adware en sus versiones gratuitas.

2. Clasificación del Malware

Acciones que realiza

✓ **Grayware:** software malicioso no dañino

Hijacking

- Cambian la configuración del navegador: página de inicio, Favoritos, etc.
- Añaden nuevas barras de herramientas
- Intentan aumentar la cantidad de visitas que recibe una web.

Jokes

- No realiza acciones pero puede hacer creer que se realizan:
 - Borrar el contenido del disco
 - Enviar información por la red, etc.
- Su finalidad es asustar al usuario con algún tipo de broma

2. Clasificación del Malware

Acciones que realiza

✓ **Grayware:** software malicioso no dañino

Bulo o Hoaxes

- Se propagan por correo electrónico
- Alerta a los usuarios de una amenaza no real: virus, estafa, fallo de seguridad
- Utilizan técnicas de ingeniería social para que los usuarios reenvíen el correo a otras personas

2. Clasificación del Malware

Acciones que realiza

✓ Software malicioso dañino

- Representan una amenaza real y atentan contra la seguridad de los equipos (cuentas, claves...)
- Sacan provecho de las vulnerabilidades de los sistemas y las aplicaciones.

Ransomware

- Proviene de las palabras ransom (rescate) y software.
- Cifra archivos importantes del disco duro para exigir el pago de dinero a cambio de las contraseñas para descifrarlo.

Rogueware

- Proviene de rogue (falso) y software.
- Hace creer al usuario que su ordenador está infectado con un virus (sin estarlo) y que la única solución es un software por que debe pagar una cantidad de dinero o descargar un software que resulta después ser malware.

2. Clasificación del Malware

Acciones que realiza

✓ Software malicioso dañino

Password stealer

- Modifican el navegador para que capture y envíe contraseñas cuando son introducidas por el usuario.

Bombas lógicas

- Se pone en marcha cuando se cumple alguna condición: un día completo, un cambio en un archivo de disco, un dato en la base de datos, etc.

Keylogger y backdoor's

- Vistos en el apartado de troyanos

3. Denegación de servicio

Denegación de servicio o Denial of Service (DoS):

Se define como la imposibilidad de acceder temporal o permanentemente a un recurso por parte del usuario legítimo.

Los ataques tratan de conseguir una degradación del servicio o recurso, ocasionando que deje de ser accesible para usuarios legítimos.

Tipos de ataques DoS, según el origen de los atacantes

Ataques internos

- Provocados por usuarios de la propia organización.
- Por **desconocimiento** o de forma **intencionada**.
- Provocan la degradación de un recurso o servicio

Ataques externos

- El atacante es una entidad ajena a la organización.
- Se aprovechan **vulnerabilidades en el sistema**: Bugs de programas, falta de autenticación de usuarios, etc.

4. Publicidad y correo no deseado

- Es todo **correo no esperado ni solicitado** por el usuario.
- Se envía de forma masiva y puede saturar la bandeja de entrada de la cuenta de correo con información no deseada.

Las **intenciones** con las que envía son varias:

- Propagar software malicioso
- Difundir bromas o hoax con fines de notoriedad o repercusión
- Distribuir publicidad comercial

El correo no deseado con fines publicitarios o económicos se denomina **spam**. Ojo: no todo el correo no deseado es spam, con frecuencia se tiende a generalizar

Algunos navegadores y antivirus o redireccionan el correo no deseado a una bandeja especial o lo eliminan directamente, pero.....aunque detectan bien el spam, no tanto el resto de correo no deseado.

En España, el correo electrónico no deseado está prohibido por la **Ley 34/2002 de 11 de Julio de Servicios de la Sociedad de la Información y de Comercio Electrónico** (LSSICE)

- Prohíbe el envío de publicidad y promoción que no hubiera sido solicitado o autorizado.
- El correo debe incluir una dirección de correo válida dónde puede exigirse el cese del envío.

5. Ingeniería Social. Fraudes informáticos

La **ingeniería social** es una forma de fraude informático muy utilizado que consiste en manipular el comportamiento natural de los humanos mediante engaños y mentiras.

Existen diversas técnicas: phishing, vishing, smishing, grooming, ciber-bulling, etc.

Se pueden clasificar en **tres categorías**:

- ✓ Suplantación de identidad
- ✓ Cadenas de correos
- ✓ Correos millonarios



5. Ingeniería Social. Fraudes Informáticos

Suplantación de identidad

La suplantación de identidad es un tipo de fraude que consiste en hacerse pasar por otra persona. Los atacantes obtienen credenciales de otros usuarios y los suplantan.

Phishing

- El atacante crea una página web falsa aparentemente idéntica a la que requiere autenticación.
- Cuando el cliente introduce datos confidenciales (contraseña, número de tarjeta de crédito, PIN, etc.) el atacante obtiene la información que necesita para suplantarle.
- Para que el usuario no sospeche, se suele mostrar un mensaje de que el servicio no está disponible temporalmente por algún motivo.



5. Ingeniería Social. Fraudes Informáticos

Suplantación de identidad

Pharming

- Es una técnica que suplanta el sistema de resolución de nombres de dominio (DNS) → Las peticiones a una página web se redireccionan a una página web falsa.
- Hay varias técnicas de suplantación del DNS: modificación del archivo hosts, modificación de información en el servidor,...

Vishing

- Es una técnica similar al phishing, pero utiliza como medio el protocolo de voz sobre IP (VoIP)
- La víctima recibe una llamada y se le indica que debe teclear desde el terminal un determinado dato confidencial para realizar una acción o deben hacer una llamada a un número 901 o 902 para verificar datos (nº cuenta, nº tarjeta...).

5. Ingeniería Social. Fraudes Informáticos

Suplantación de identidad

SMiShing

- El engaño se produce vía SMS
- Se pide al usuario que vaya a una determinada página por algún motivo importante, bloqueo de cuenta, etc.
- Para acceder al servicio supuestamente “bloqueado” debe introducir datos personales, descargar algún archivo (será un troyano), etc.

Grooming

- Acoso a menores por parte de un adulto que trata de ganarse su confianza o lo coacciona para que realice algún tipo de práctica sexual.



5. Ingeniería Social. Fraudes Informáticos

Cadena de correos

Son mensajes en los que se invita a difundirlo al mayor número posible de personas con el fin de obtener las direcciones de correo.

Los argumentos son muy variables:

- Deseos de paz, amor, felicidad
- Avisos de borrado de cuentas o que determinadas aplicaciones serán gratuitas.
- Noticias falsas que alarmen a los usuarios

Detrás de estos correos hay una persona u organización interesada en obtener direcciones de correo válidas par enviar spam.

Recomendaciones:

- Romper la cadena. No enviar. Comprobar su veracidad.
- En caso de reenviar, siempre en copia oculta, no en el campo destinatarios.
- Revisar el contenido del correo, borrando el las direcciones de correo procedentes de reenvíos anteriores.

5. Ingeniería Social. Fraudes Informáticos

Correos millonarios

Consiste en el envío de correos prometiendo a los usuarios hacerse ricos fácilmente.

También denominado «estafa nigeriana» o «carta nigeriana»

Ejemplos:

- Millonario que ha fallecido sin herederos
- Premios de lotería que se ha ganado
- Envío de dinero a familiares, etc.

